

Executive summary: A dynamic application security assessment was conducted against OWASP Juice Shop using OWASP ZAP. Multiple vulnerabilities were identified, including cross-site scripting, security misconfigurations, and information disclosure weaknesses.

Target: <http://localhost:3000>

Tool: OWASP ZAP

Assessment type: DAST

Vulnerability Name: Cross-Domain Misconfiguration (CORS issue)

Description: Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server

Evidence: Access-Control-Allow-Origin: *

Screenshot:

Cross-Domain Misconfiguration
URL: http://localhost:3000/chunk-PX7UKXVL.js
Risk:  Medium
Confidence: Medium
Parameter:
Attack:
Evidence: Access-Control-Allow-Origin: *
CWE ID: 264
WASC ID: 14
Source: Passive (10098 – Cross-Domain Misconfiguration)
Input Vector:
Description:
Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
Other Info:
The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access

Risk Rating: Medium

CVSS Score: 6.5

Remediation: Restrict Access-Control-Allow-Origin to trusted domains instead of using *. Disable Access-Control-Allow-Credentials unless explicitly required. Limit allowed HTTP methods (e.g., GET, POST only where necessary). Validate and whitelist specific origins at the backend rather than using dynamic reflection of request origins.

OWASP Top 10: A05: Security Misconfiguration

Vulnerability Name: CSP Failure to Define Directive

Description: The contents security policy fails to define one of the directives that has no fallback. Missing/excluding them is the same thing as allowing anything.

Evidence: default-src 'none'

Screenshot:

CSP: Failure to Define Directive with No Fallback

URL: http://localhost:3000/assets

Risk:  Medium

Confidence: High

Parameter: Content-Security-Policy

Attack:

Evidence: default-src 'none'

CWE ID: 693

WASC ID: 15

Source: Passive (10055 – CSP)

Alert Reference: 10055-13

Input Vector:

Description:

The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.

Other Info:

The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.

Risk Rating: Medium

CVSS Score: 6.5

Remediation: Implement a strict Content Security Policy (CSP) header to control allowed script, style, and resource sources. Define explicit directives such as default-src, script-src, and object-src to prevent execution of unauthorized scripts. Avoid using wildcard (*) sources and inline scripts where possible. Test CSP in report-only mode before enforcing to avoid breaking application functionality.

OWASP Top 10: A05: Security Misconfiguration

Vulnerability name: HTTP only site

Description: The site is only served under HTTP and not HTTPS

Evidence: OWASP ZAP identified that the application is served over HTTP instead of HTTPS. The response is transmitted without encryption, allowing potential interception of data in transit.

Screenshot:

HTTP Only Site

URL: http://localhost:3000/ftp/

Risk:  Medium

Confidence: Medium

Parameter:

Attack:

Evidence:

CWE ID: 311

WASC ID: 4

Source: Active (10106 – HTTP Only Site)

Input Vector:

Description:

The site is only served under HTTP and not HTTPS.

Other Info:

Failed to connect.

ZAP attempted to connect via: https://localhost:3000/ftp/

Solution:

Risk Rating: Medium

CVSS Score: 6.9

Remediation: Enforce HTTPS across all application endpoints using TLS 1.2 or higher, redirect all HTTP traffic (port 80) to HTTPS (port 443), implement HTTP Strict Transport Security (HSTS) to force secure connections in browsers, disable insecure HTTP access at the web server or reverse proxy level (e.g., Nginx/Apache configuration)

OWASP Top 10: A02: Cryptographic Failures

Vulnerability Name: Content Security Policy (CSP) Header Not Set

Description: Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

Evidence: ZAP Alert indicates that the Content Security Policy (CSP) HTTP header is not present in the server response.

Screenshot:



The screenshot shows a ZAP alert interface. At the top, the title is 'Content Security Policy (CSP) Header Not Set'. Below this, several fields are listed: 'URL:' with the value 'http://localhost:3000', 'Risk:' with a medium risk icon and the text 'Medium', 'Confidence:' with the value 'High', 'Parameter:', 'Attack:' with a vertical bar, 'Evidence:', 'CWE ID:' with the value '693', 'WASC ID:' with the value '15', 'Source:' with the value 'Passive (10038 - Content Security Policy (CSP) Header Not Set)', and 'Alert Reference:' with the value '10038-1'. Below these fields is an 'Input Vector:' section, which contains a 'Description:' field with the text: 'Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of'. Below the description is an 'Other Info:' field, which is currently empty.

Risk Rating: Medium

CVSS Score: 6.5

Remediation: Implement a Content Security Policy (CSP) header to restrict allowed content sources, define explicit directives such as default-src, script-src, style-src, and object-src, restrict script execution to trusted domains only and avoid using wildcards (*), avoid inline scripts where possible or use nonces/hashes for safe execution, test CSP in Content-Security-Policy-Report-Only mode before enforcing to prevent breaking functionality

OWASP Top 10: A05: Security Misconfiguration